Seguridad de Operaciones

Exposición grupal

Simulación de incidentes

Profesor/a:

Bryan Calderón Montero

Integrantes :

Jose Umaña Villegas
Fabricio Flores Zuñiga
Justin Bustamante Salas
Daniel Fernandez Picado
Génesis Castro Quesada
Jose Pablo Picado Chaves

Universidad CENFOTEC

Índice

Instrucciones **3**
- Objetivo 3
- Requisitos 3
- Entregable 3
- Evaluación de la exposición 4

Desarrollo **5**
- Laboratorio I. Introduction to SIEM 5
- Preguntas de reflexión 5
- Laboratorio II. SOC L1 Alert Triage 6
- Preguntas de reflexión 6

Conclusiones 7

Instrucciones

Exposición

Grupal: Simulación de incidentes Parte 1.

Objetivo

- Capacitar a los participantes para comprender el rol, componentes y funcionamiento básico de un SIEM y aplicar ese conocimiento en el laboratorio de la sala para recopilar, analizar, correlacionar y clasificar eventos de seguridad a partir de registros centralizados.

Requisitos

- M1. Introducción a la seguridad de operaciones.
- M2. Configuración segura de sistemas operativos.
- M3. Monitoreo de actividades y registros de eventos.
- M4. Gestión de parches, actualizaciones e incidentes de seguridad operacional.
- M5. Seguridad en configuraciones de red.

Instrucciones

• Realizar las actividades de las siguientes salas de TryHackMe:
https://tryhackme.com/room/introtosiem
https://tryhackme.com/room/socl1alerttriage

Entregable

(Semana 12)
Se debe de realizar una pequeña presentación que debe incluir.

- Portada.
- Agenda.
- Desarrollo Teórico:
  - ¿Por qué necesitamos un SIEM?
  - Explicar la diferencia de host-centric y network-centric, brindar ejemplos.

- Explicar las fuentes de logs y métodos de ingestión.
- Explicar el flujo de correlación con un diagrama (drawio.com / lucidchart.com).

- Explicar sobre el análisis de alertas (Triage).
- Explicar los roles involucrados en el SOC.

- Laboratorio 1:
  - Explicar el proceso realizado en laboratorio, que considera como grupo relevante de la actividad.
- Laboratorio 2:
  - Qué aprendieron como grupo sobre el manejo de alertas.
  - Considera relevante la práctica, explique por qué.
- Conclusiones.

Entregue el trabajo en formato PowerPoint en el aula virtual, asegurándose de que esté bien estructurado y sea comprensible.

Evaluación de la exposición

- Gestión del tiempo, 20 minutos máximo por grupo (15%).
- Dominio del tema (25%).
- Análisis detallado del caso (40%).
- Propuestas de mejora y reflexión (20%).

Desarrollo

Desarrollo Teórico

¿Por qué necesitamos un SIEM?

Necesitamos un SIEM porque la seguridad actual genera tal volumen de eventos que resulta imposible para un equipo humano correlacionar amenazas de forma manual y en tiempo real. Los atacantes operan de manera sigilosa y distribuida, y solo una plataforma centralizada puede agregar, normalizar y analizar esa información para detectar patrones anómalos. Sin ella, la visibilidad es fragmentada, las respuestas son lentas y los incidentes críticos pasan desapercibidos hasta que ya es demasiado tarde

Explicar la diferencia de host-centric y network-centric, brindar ejemplos.

La diferencia entre host-centric y network-centric se centra en el enfoque de los mismos, ya que para el host-centric, el enfoque está en los endpoints o hosts, lo cual hace referencia a que el SIEM recibe los logs que generan directamente los dispositivos finales como lo son los logs de Windows, Sysmon, logs de Linux (auth.log, syslog) y el antivirus o EDR, el análisis se centra en lo que ocurre dentro del host.

Por otro lado, cuando se habla de network-centric, el enfoque se redirige a los dispositivos de red, ya que el SIEM recibe los logs generados por la infraestructura de red como los firewalls, los IDS/IPS (Snort, Suricata), routers y switches, para este segundo apartado, el análisis se centra en el tráfico y las comunicaciones.

Finalmente, se puede resumir en que los logs host-centric son los que permiten ver qué hizo el atacante dentro del sistema y los network-centric son los que muestran cómo se movió o se comunicó el atacante.

Fuentes de logs y métodos de ingestión.

Las fuentes de logs son la materia prima de cualquier SIEM: sin estos registros fiables y bien estructurados no es posible detectar, investigar ni responder incidentes con eficacia, ¿Porque? cada dispositivo en una genera un registro propio cada vez que hace una acción como: accediendo páginas web, Inicio/cierres de sesión conexión por puertos (SSH), la copia de un archivo en concreto y etc.

Hay varios tipos de de fuentes de logs, pero mencionaremos los principales:

1. Host-centric (centrados en el equipo)
    - ➢ Son registros generados por el propio sistema y aplicaciones que corren mediante el host como: EventLog, audit, logs de aplicaciones y logs de bases de datos locales, ¿Qué registran? inicios/cierres de sesión, intentos autenticación, ejecución de procesos y permiten la reconstrucción/granularidad detecciones maliciosas con verificación de cambios administrativos, a pesar volumen elevado, formatos variados y posibilidad de manipulación local.

2. Network-centric (centrados en la red)
    - ➢ Generados por dispositivos que observan el tráfico entre hosts o hacia internet como: firewalls, routers, IDS/IPS, balanceadores registros de DNS; esto registran sesiones (origen/destino de IPs, puertos, y bytes) filtrados (permitido/denegado), enlaces consultables y dominios. Propociona detección de escaneos, movimientos laterales y comunicación (comando y control), tiene su limitación de cifrado del tráfico (limita el contenido), alto volumen y falsos positivos por tráfico legítimo.

3. Aplicaciones y bases de datos
    - ➢ Logs generados apps web, APIs y sistemas gestión de datos, como: acceso/errores de servidores web, consultas SQL, logs de APIs y exportación de registros. Revisa las URLs en solicitud, parámetros, códigos HTTP, consulta de la base de datos y errores de aplicación aunque hay necesidad de correlacionar con logs de red y red para convalidación de las sospechas.

4. Endpoints y EDRS
    - ➢ Agentes especializados que registran el comportamiento en estaciones y servidores EDR comerciales (Endpoint Detection and Response), open source que capturan los procesos, hashes y el comportamiento de respuesta. Permite detección temprana de actividad maliciosa y capacidad de respuesta automática, depende mucho coste y necesidad de la gestión centralizada de la empresa.

5. Servicios Nube
    - ➢ Telemetría de proveedores cloud (IAM, audit de API, eventos de infraestructura), esta CloudTrail, CloudWatch, registros de de IAM, plataformas SaaS, permiten llamadas a la Interfaz de Programación de Aplicaciones, cambios de configuración, moldear el apartado de recursos y las actividades de las cuentas porque nos da visibilidad administrativa, ajustar la infraestructura pese adaptación distintos proveedores y costes ingestión/retención.

Además fuentes de logs, tenemos los métodos de gestión cuál es el proceso por cual los logs se movilizan del origen hasta colector o SIEM, donde estos se normalizan y se almacenan con debido análisis, base la calidad de la ingestión determinada posteriormente de los datos:

1. Agentes/reenviadores de endpoints
    - Agente ligero instalado en cada host que captura eventos del sistema y aplicaciones y los envía al colector (como Wazuh!), permite buffering local ante caídas de red, cifrado en tránsito y filtrado de origen.

2. Syslog (UDP/TCP/TLS)
    - Protocolo estándar para envío de mensajes de log (Unix/Linux) y muchos dispositivos de red, ampliamente soportable para routers, switches, firewalls y sistemas que ya emiten syslog.

3. Conectores / APIs nativos

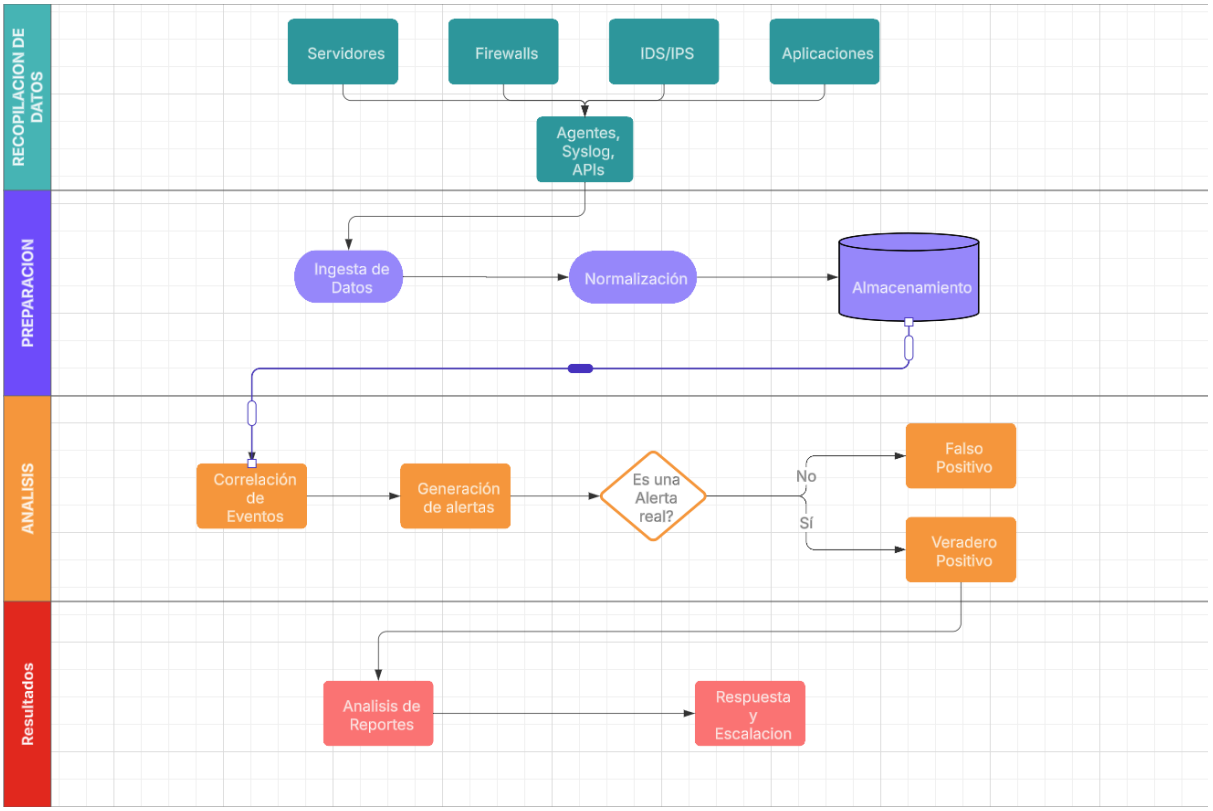
- Integración directa con Interfaz de Programación de Aplicaciones o conectores oficiales (por ejemplo AWS Cloudtrail) con datos estructurados, autenticación segura y enriquecimiento nativo.

4. Reenvío por puerto / ingestión directa (TCP/JSON)
   - ➢ Dispositivos o aplicaciones envían los logs en formato JSON o texto a un puerto colector del SIEM, la ventaja es tiempo real sin necesidad de agentes, y puede enviarlos los logs por red.

5. NetFlow / IPFIX / registros de flujo
   - Capturación de metadatos de flujo de red (conexiones,bytes, duración) para análisis de volumen y patrones. Es bastante eficiente para detectar anomalías (tráfico) y exfiltración por volumen.

6. Carga manual de ficheros
   - Subida manual de archivos de log (CSV,JSON,Text) para análisis forense y auditorías, útil para indagar investigaciones históricas o migraciones este requiere normalización previa.

Diagrama de flujo de correlación de SIEM



Análisis de alertas (Triage).

El análisis de alertas o triage es el proceso inicial que realiza un analista de seguridad para revisar, priorizar y clasificar alertas generadas por herramientas de monitoreo como un Security Information and Event Management (SIEM).

Su objetivo principal es determinar rápidamente si una alerta representa una amenaza real o si corresponde a una actividad legítima dentro de la organización.

¿Qué se busca en el triage?

Durante el análisis se revisan varios elementos:

- usuario involucrado
- equipo afectado
- dirección IP origen y destino
- hora del evento

- tipo de actividad detectada
- contexto de red
- eventos relacionados antes y después de la alerta

Esto permite entender si el comportamiento observado es normal o sospechoso.

Clasificación de una alerta

Después del análisis, la alerta se clasifica como:

Verdadero positivo (True Positive)

Cuando se confirma que existe una actividad maliciosa o una amenaza real.

Ejemplo:

- malware
- phishing
- exfiltración de datos

Falso positivo (False Positive)

Cuando la alerta fue generada por una actividad legítima.

Ejemplo:

- uso normal de Zoom Communications
- descarga autorizada desde GitHub

Priorización en el triage

No todas las alertas se atienden en el mismo orden.

Se priorizan según severidad:

- **Critical**
- **High**
- **Medium**
- **Low**

Las alertas críticas se atienden primero porque pueden representar mayor impacto para la organización.

Importancia del triage

El triage permite:

- reducir falsos positivos
- responder más rápido a incidentes reales
- optimizar el tiempo del analista
- evitar que amenazas importantes pasen desapercibidas

Roles involucrados en el SOC.

Especialista en Triaje (Nivel 1)

Los analistas de Nivel 1 son los principales responsables de recopilar datos brutos y revisar alarmas y alertas.

Responsable de respuesta a incidentes (Nivel 2)

Revisan los incidentes de seguridad de mayor prioridad escalados por los especialistas de triaje y realizan una evaluación más exhaustiva utilizando inteligencia de amenazas.

Cazador de amenazas (Nivel 3)

Son el personal más experimentado, ellos se encargan de gestionar los incidentes más graves que se les envían por parte de los equipos de respuestas de incidentes.

Gerente del SOC

El gerente del SOC supervisa las operaciones diarias del equipo del SOC y garantiza que los sistemas y redes de la organización sean seguros y funcionen sin problemas.

Ingeniero SOC

Los ingenieros de seguridad diseñan, implementan y mantienen los controles y defensas técnicas que se utilizan para proteger los activos y sistemas de la organización

Director de Seguridad de la Información (CISO)

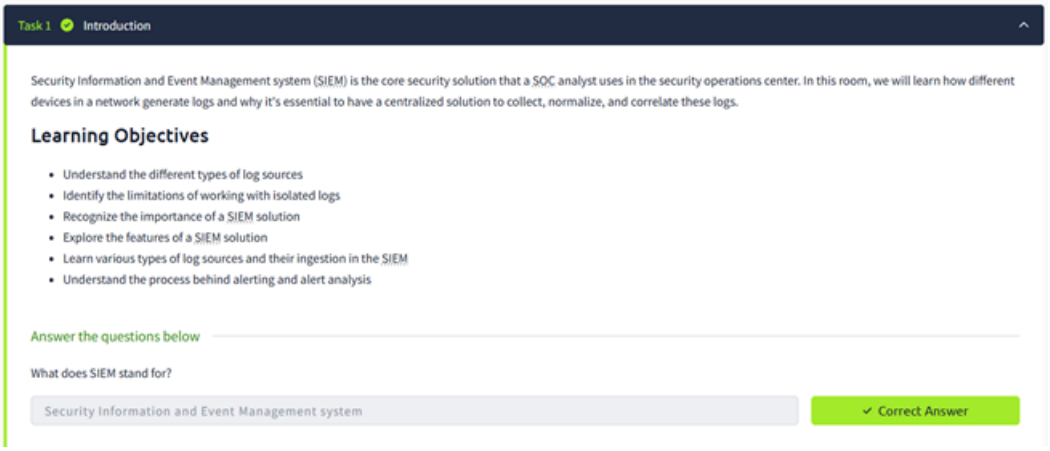
Es un ejecutivo de alto nivel que supervisa la estrategia y las operaciones de ciberseguridad de una organización. El CISO forma parte del equipo directivo de la empresa y reporta directamente al CEO u otro gerente de nivel ejecutivo.

Laboratorio I. Introduction to SIEM

Task 1. Introduction

What does SIEM stand for?

Security Information and Event Management system (SIEM) es la solución de seguridad central que utiliza un analista en el SOC (Security Operations Center).

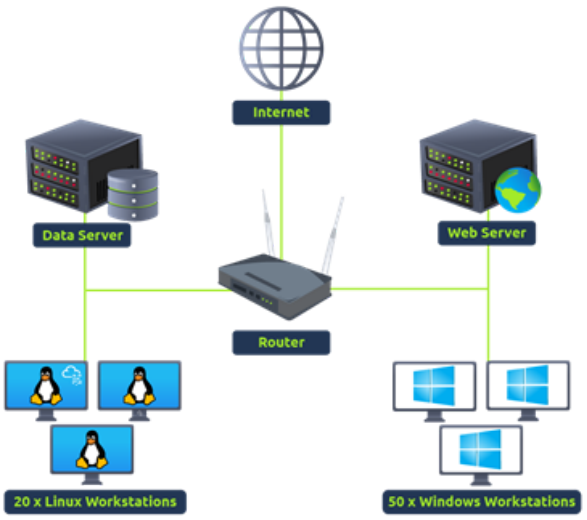


Task 2. Logs Everywhere, Answers Nowhere

Is Registry-related activity host-centric or network-centric?

Is VPN-related activity host-centric or network-centric?

Varios dispositivos en una red se comunican entre sí y, la mayoría de las veces, con Internet a través de un router.



Estos dispositivos generan continuamente registros de las actividades que ocurren en su interior. También podemos llamar a estos dispositivos fuentes de registro. Los registros que generan sirven como un rastreo de todas las actividades y son extremadamente útiles para identificar actividades maliciosas o para solucionar problemas en general.

Categorías en las que se dividen las fuentes de logs:

1. Host-Centric Log Sources

Capturan eventos que ocurrieron dentro o que están relacionados con el host. Los dispositivos que generan registros centrados en el host incluyen Windows, Linux, servidores, entre otros. Algunos ejemplos de Host-Centric logs son los siguientes:

· Cuando un usuario accede a un documento.

· Cuando un usuario se intenta autenticar.

· Una actividad de ejecución de procesos.

· Un proceso que añade, edita, elimina una clave o valor del registro.

· Una ejecución de PowerShell.

2. Network-Centric Log Sources

Los registros que se relacionan con la red se generan cuando los hosts se comunican entre sí o acceden a internet para visitar un sitio web. Los firewalls, IDS/IPS y routers, son los dispositivos que generan este tipo de registros. Ahora bien, algunos ejemplos de Network-Centric logs son los siguientes:

· Conexión SSH.

· Un archivo que se accede a través de FTP (File Transfer Protocol).

· Tráfico en la web.

· Un usuario accediendo a los recursos de la empresa a través de VPN (Virtual Private Network).

· Compartición de archivos en red Actividad.

Retos al analizar los logs e identificar actividades maliciosas

1. Numerosas fuentes de logs

Una red tiene muchas fuentes de registro, ya que se generan cientos de eventos por segundo, estos registros están dispersos en diferentes dispositivos y examinar los registros en cada dispositivo uno por uno en caso de un incidente, puede ser tardado y tedioso.

2. Sin centralización

Los registros redicen en las máquinas en las que se generan los mismos, por lo que puede requerirse el conectarse con cada fuente de registro mediante SSH, RDP, entre otros con el fin de lograr analizar los registros de múltiples fuentes de logs, lo cual es bastante ineficiente y puede generar una considerable pérdida de tiempo, el cual es vital en investigaciones.

3. Contexto limitado

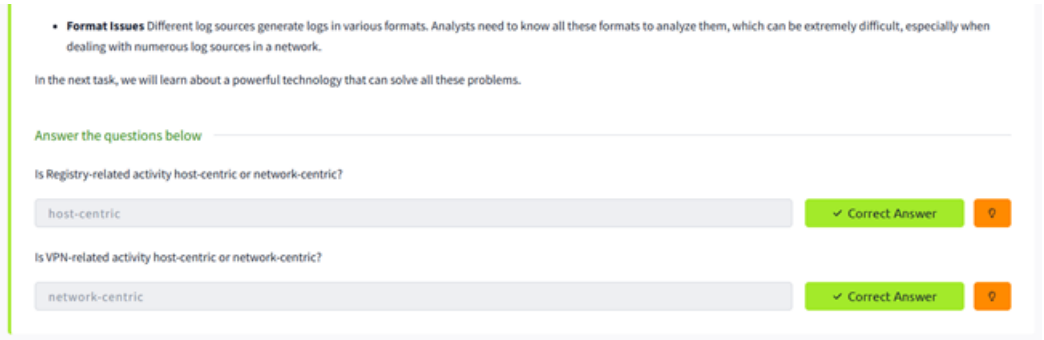
Los registros no pueden contar toda la historia de una actividad. Durante un incidente, las actividades individuales en diferentes fuentes de registro pueden parecer inofensivas. Pero si estos registros están correlacionados, pueden indicar una historia completamente diferente. Por ejemplo, observamos un evento de acceso a archivos en un sistema, que generalmente es una actividad normal. Sin embargo, si se correlacionan diferentes fuentes de registro, se puede llegar a saber que este archivo fue accedido por un usuario que accedió a esta máquina mediante movimiento lateral tras comprometer otra máquina en la red.

4. Análisis limitado

Las fuentes generan una cantidad considerable de registros por segundo, analizar cada uno de ellos de forma manual con el fin de identificar la actividad anormal es casi imposible, ya que al final los analistas podrían perder registros relevantes dentro de su análisis, debido a la gran cantidad de logs.

5. Problemas de formato

Para este punto, se debe considerar que los logs se generan en varios formatos, por lo que los analistas requieren conocer todos los formatos para lograr analizarlos, esto puede ser bastante complicado, especialmente cuando se trata de una cantidad considerable de registros en una red.



Task 3. Why SIEM?

¿Por qué es necesario un SIEM?

En un entorno de TI moderno, los dispositivos y sistemas generan una enorme cantidad de registros (logs) cada segundo. Estos registros incluyen desde intentos de inicio de sesión hasta cambios en archivos y tráfico de red. Sin embargo, analizar manualmente estos datos en busca de actividades maliciosas es prácticamente imposible debido al volumen y la complejidad de la información. Aquí es donde entra en juego el SIEM.

El propósito fundamental de un SIEM es proporcionar correlación sobre los datos recopilados para detectar amenazas. La correlación permite conectar eventos aparentemente aislados de diferentes fuentes para formar una imagen coherente de un posible incidente de seguridad. Por ejemplo, un inicio de sesión fallido seguido de un inicio de sesión exitoso desde la misma IP en segundos podría ser un ataque de diccionario.

Beneficios clave de un SIEM

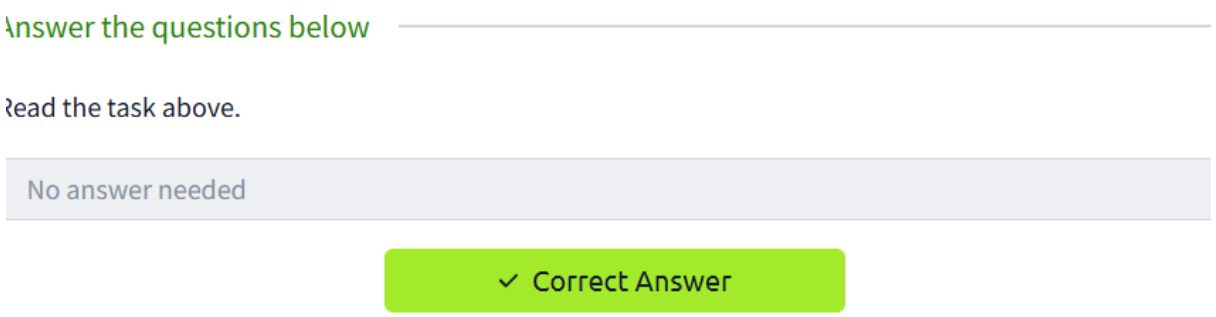
Un SIEM ofrece múltiples ventajas para una organización:

1. Detección oportuna de amenazas: Al correlacionar eventos en tiempo real, el SIEM puede identificar patrones de ataque que de otro modo pasarían desapercibidos. Cuando se detecta una amenaza o se cruza un umbral predefinido, se genera una alerta que permite a los analistas tomar medidas inmediatas.
2. Visibilidad centralizada: Un SIEM proporciona una visión integral de toda la infraestructura de red, combinando datos de firewalls, servidores, endpoints y aplicaciones en un solo lugar.
3. Capacidad de investigación histórica: Permite almacenar logs a largo plazo, facilitando la investigación de incidentes pasados, el análisis forense y el cumplimiento normativo.
4. Reducción de ruido: Ayuda a identificar falsos positivos y a ajustar reglas para reducir alertas innecesarias, permitiendo a los analistas centrarse en amenazas reales.

El rol del analista SOC

Los analistas de un Centro de Operaciones de Seguridad (SOC) utilizan el SIEM para:

- Monitorear e investigar alertas.
- Identificar y ajustar reglas que generan falsos positivos.
- Elaborar reportes y garantizar el cumplimiento normativo.
- Detectar puntos ciegos en la visibilidad de la red y cubrirlos.



Task 4. Log Sources and Ingestion

Fuentes de registro

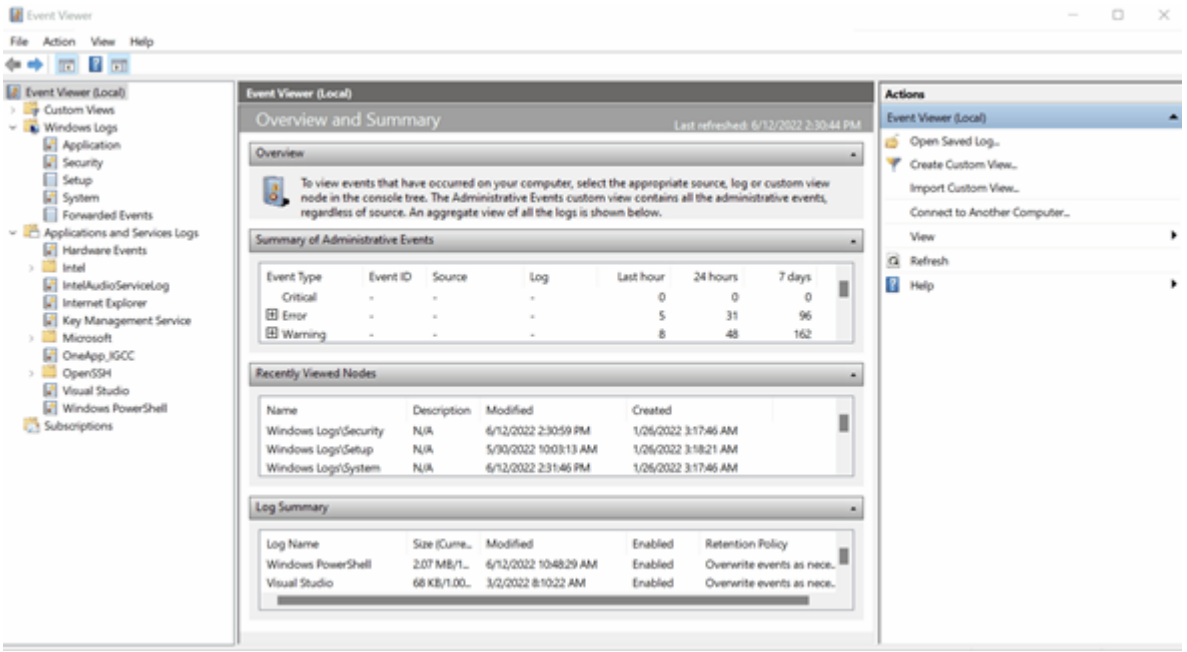
Cada dispositivo en una red genera un registro cada vez que se realiza una acción dentro ese dispositivo, por ejemplo, visitar una página web, iniciar conexión por SSH

(Port 22) o la copia de archivo, y esas acciones se convierten logs que es la base del SIEM permitiendo saber:

- ¿Quién?: Identifica al usuario, cuenta, dirección IP o máquina responsable de la actividad sospechosa.
- ¿Qué?: Define la acción específica que ocurrió (por ejemplo, un intento fallido de inicio de sesión, una transferencia de datos masiva, o un cambio en los privilegios de un archivo).
- ¿Dónde?: Indica el sistema, servidor, aplicación, firewall o ubicación geográfica donde se detectó el evento.
- ¿Cuándo?: Establece la fecha y hora exacta del evento, crucial para correlacionar eventos de distintas fuentes.
- ¿Por qué?: Contextualiza el incidente mediante inteligencia de amenazas o correlación de datos para determinar si se trata de un ataque, un error de configuración o un comportamiento legítimo.

<u>Máquina Windows</u>

➢ Windows guarda todos los sucesos en el Visor de eventos, donde cada tipo de actividad recibe un ID único que facilita su seguimiento. En esa herramienta se registran eventos como inicios y cierres de sesión, errores del sistema, alertas de seguridad y cambios en la configuración; estos registros de cada equipo se recopilan y se envían al SIEM para su monitorización centralizada. Al centralizar y normalizar estos logs se facilita la detección de incidentes, la correlación entre equipos y la investigación forense, además de apoyar auditorías y respuestas rápidas ante amenazas.



<u>Máquina Linux</u>

➢ Linux guarda eventos del sistema (errores, avisos, accesos, actividad del kernel) en archivos bajo /var/log; esos ficheros se envían al SIEM para monitorizar y analizar de forma continua.

- /var/log/httpd: Registros del servidor web (peticiones, códigos de respuesta, errores); sirven para detectar tráfico anómalo, ataques web o fallos en la aplicación.
- /var/log/cron: Registra ejecuciones y errores de tareas programadas (cron jobs); permite comprobar si una tarea se ejecutó, falló o se ejecutó en un horario inesperado.
- /var/log/auth.log y /var/log/secure: Eventos de autenticación (inicios/cierres de sesión, sudo, intentos fallidos); esenciales para identificar accesos no autorizados.
- /var/log/kern: Mensajes del kernel sobre hardware y controladores; útil para diagnosticar fallos de dispositivos o errores del núcleo.

Ejemplo de un registro de cron:

```
May 28 13:04:20 ebr crond[2843]: /usr/sbin/crond 4.4 dillon's cron daemon, started with loglevel notice
May 28 13:04:20 ebr crond[2843]: no timestamp found (user root job sys-hourly)
May 28 13:04:20 ebr crond[2843]: no timestamp found (user root job sys-daily)
May 28 13:04:20 ebr crond[2843]: no timestamp found (user root job sys-weekly)
May 28 13:04:20 ebr crond[2843]: no timestamp found (user root job sys-monthly
Jun 13 07:46:22 ebr crond[3592]: unable to exec /usr/sbin/sendmail: cron output for user root job sys-daily to
```

- Línea 1
  - ➔ /usr/sbin/crond 4.4 dillon's cron daemon, started with loglevel notice
    - ❖ Indica que el servicio crond arrancó correctamente (versión 4.4) y que el nivel de registro es notice.
- Líneas 2-5
  - ➔ no timestamp found (user root job sys-hourly|sys-daily|sys-weekly|sys-monthly)
    - ❖ Significa que cron ejecutó los jobs del sistema (sys-hourly, sys-daily, etc.) pero no encontró un timestamp en la salida de esos trabajos.
- Línea final
  - ➔ unable to exec /usr/sbin/sendmail: cron output for user root job sys-daily to /dev/null
    - ❖ Aquí cron intentó ejecutar /usr/sbin/sendmail para enviar por correo la salida del job (comportamiento por defecto si hay salida y no hay MAILTO vacío), pero no pudo ejecutar el binario (no existe, no tiene permisos o falla).

Servidor web

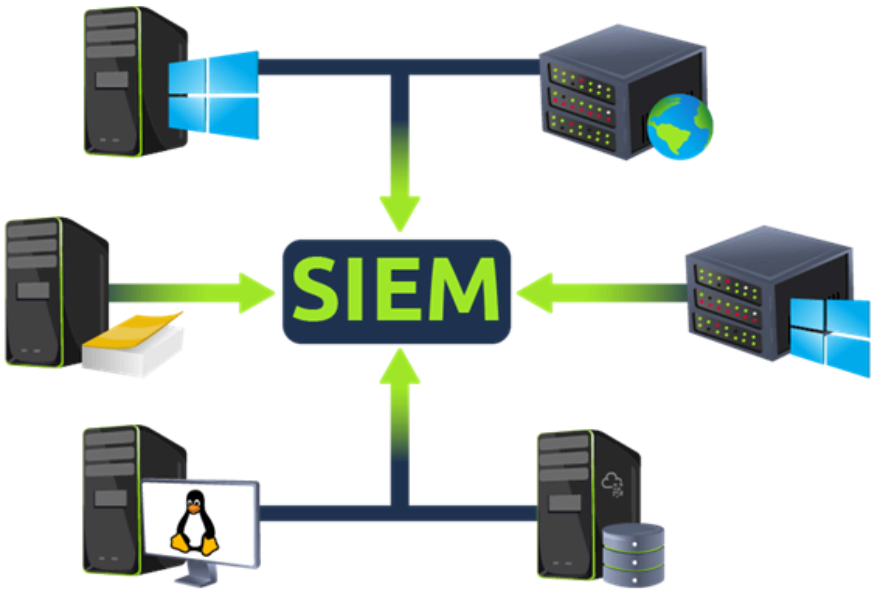
➢ Es vital registrar y vigilar todas las solicitudes y respuestas del servidor web para detectar intentos de ataque, anomalías en el tráfico y fallos en la aplicación.

- Rutas comunes
  - ➔ /var/log/apache
  - ➔ /var/log/httpd
    - ❖ Dentro de esas carpetas: access_log (o access.log) y error_log (o error.log).

Aquí hay un ejemplo de registros de Apache:

```
192.168.21.200 - - [21/March/2022:10:17:10 -0300] "GET /cgi-bin/try/ HTTP/1.0" 200 3395 "-" "Mozilla/5.0 (Win
127.0.0.1 - - [21/March/2022:10:22:04 -0300] "GET / HTTP/1.0" 200 2216 "-" "curl/7.68.0"
```

- Línea 1
  - ➔ Se registró un GET desde 192.168.21.200 a /cgi-bin/try/ el script CGI respondió con HTTP 200 y 3395 bytes, indicando que el recurso se ejecutó. Se debe verificar si la IP es interna autorizada, inspeccionar /cgi-bin/try/ y sus permisos, examinar parámetros en la URL, buscar accesos repetidos y correlacionar con logs, error_log y tráfico en el SIEM para descartar amenazas.
- Línea 2
  - ➔ Se registró una solicitud local desde 127.0.0.1 con curl, obteniendo respuesta 200 con 2216 bytes. Confirme el proceso que realizó la solicitud, valide su legitimidad, y registre en el SIEM para correlacionar con reinicios o errores. Investigue anomalías si la petición no es legítima.

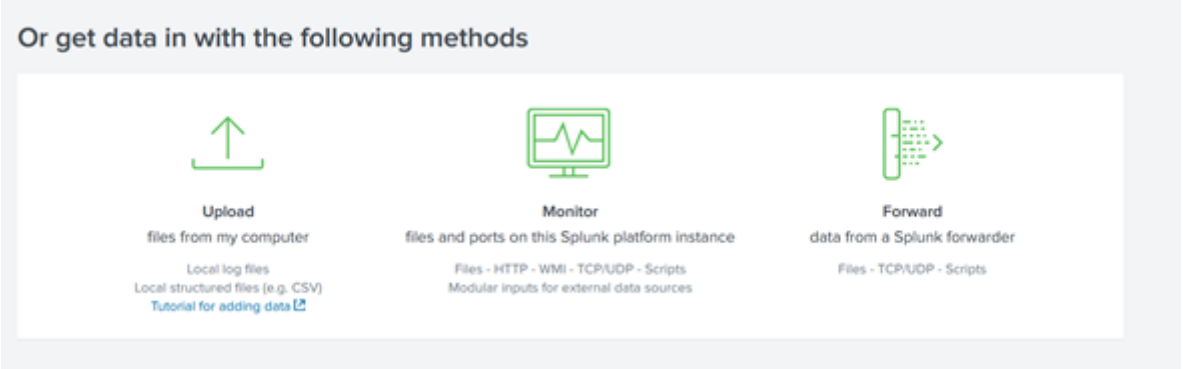


Ingesta de registros

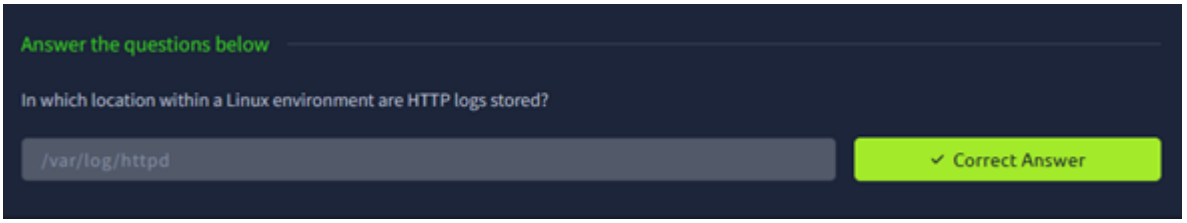
Gracias a la proporción de gran cantidad de información, podemos identificar los problemas de seguridad con mayor facilidad. Cada SIEM tiene su propio proceso de absorción de ingerir los registros, por eso algunos métodos utilizados por estos son los siguientes:

1. Agente / reenviador en el endpoint
   ➔ Un componente ligero instalado en el equipo que captura logs locales (eventos del sistema, ficheros de aplicación, registros de seguridad) y los envía al SIEM.
2. Syslog (protocolo estándar)
   ➔ Protocolo ampliamente soportado por sistemas operativos, y aplicaciones para enviar mensajes de log a un colector central.
3. Carga manual de ficheros
   ➔ Subir archivos de logs de forma puntual al SIEM para análisis offline (volcados forenses, históricos, logs de sistemas aislados).
4. Reenvío por puertos
   ➔ El SIEM expone un puerto (TCP/UDP) y los endpoints envían sus logs directamente a ese puerto; puede recibir syslog, JSON u otros formatos.

Un ejemplo de cómo Splunk se muestran varios métodos para la ingesta de registros:

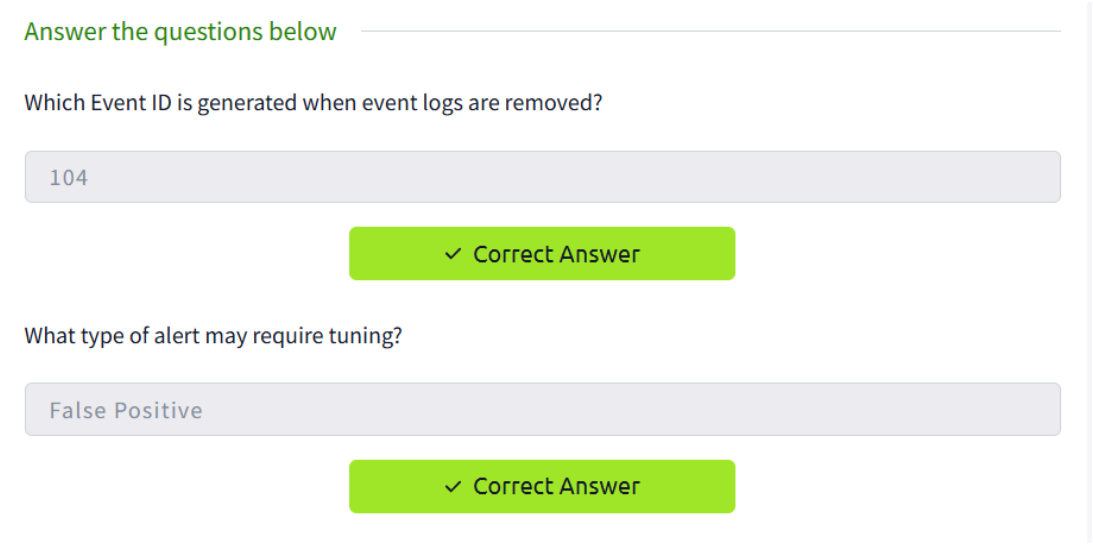


In which location within a Linux environment are HTTP logs stored?



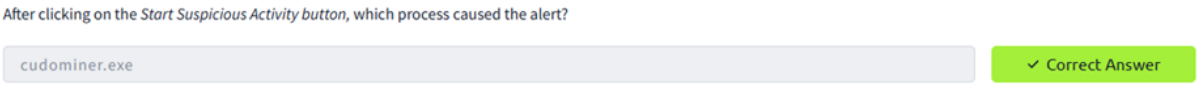
Task 5. Alerting, process and analysis

Which Event ID is generated when event logs are removed?
What type of alert may require tuning?



Task 6. Lab work

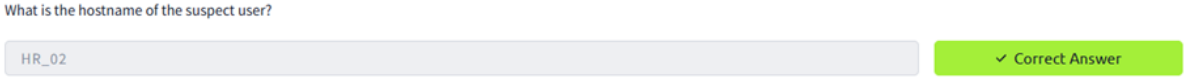
After clicking on the *Start Suspicious Activity button,* which process caused the alert?



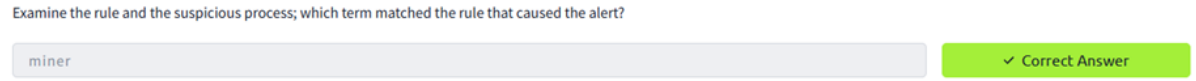
Find the event that caused the alert and identify the user responsible for the process execution.



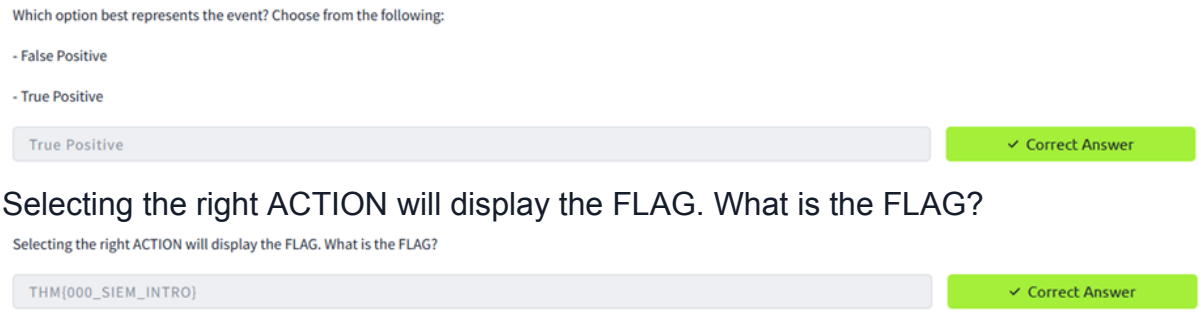
What is the hostname of the suspect user?



Examine the rule and the suspicious process; which term matched the rule that caused the alert?



Which option best represents the event? Choose from the following:



Selecting the right ACTION will display the FLAG. What is the FLAG?

Preguntas de reflexión

¿Qué considera como grupo relevante de la actividad?

Como grupo, consideramos que lo más relevante de la actividad fue comprender la importancia de la centralización de logs dentro de un SIEM y cómo esto permite correlacionar eventos que por separado parecen normales.

También fue clave entender la diferencia entre fuentes host-centric y network-centric, ya que ambas aportan contexto distinto pero complementario para la detección de amenazas.

Finalmente, destacamos el valor de la correlación de eventos para identificar comportamientos maliciosos que no serían evidentes de forma aislada.

Laboratorio II. SOC L1 Alert Triage

Task 1. Introduction

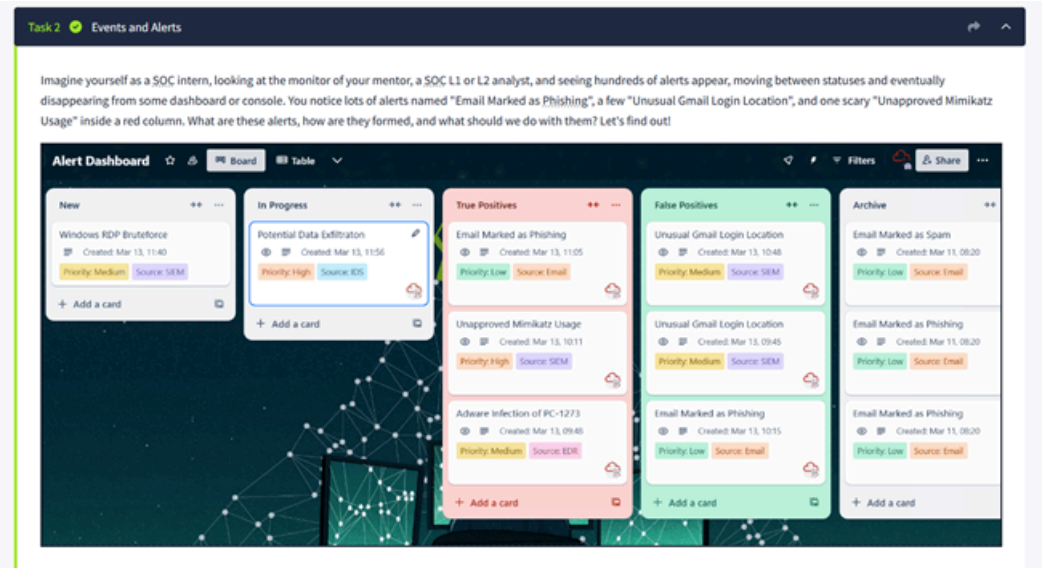
Una alerta es un concepto vital para cualquier equipo de SOC y saber cómo gestionarlo correctamente decide en última instancia si se detecta y previene una brecha de seguridad, o si se pasa por alto y es devastadora.

Task 2. Events and Alerts

What is the number of alerts you see in the SOC dashboard (opens in new tab)?
What is the name of the most recent alert you see?

Primero, debe ocurrir un evento, como inicio de sesión del usuario, lanzamiento de procesos o descarga de archivos, una vez ocurra esto, el Sistema Operativo, un firewall o un proveedor de nube debe registrar el evento. Una vez que se hace el registro del evento, todos los registros del sistema deben enviarse a una solución de seguridad, ya sea SIEM o EDR. El SOC puede recibir millones de registros al día de miles de sistemas diferentes, dentro de los cuales la mayoría de los eventos son esperados, pero algunos requieren atención.

Las alertas son las notificaciones que se generan por una solución de seguridad cuando ocurre un evento o secuencia de eventos en los que el analista debe hacer una revisión manual para destacar sólo los eventos sospechosos y anómalos.



¿Cuáles plataformas pueden utilizarse para la gestión de alertas?

Solución	Ejemplos	Descripción
SIEM Sistema	Splunk ES, Elastic	SIEM Tienen sólidas capacidades de gestión de alertas y son la opción perfecta para la mayoría de equipos de SOC.
EDR o NDR	MS Defender, CrowdStrike	Mientras EDR y NDR proporciona sus propios paneles de alerta, que se prefiere utilizar SIEM o SOAR
SOAR (Security Orchestration, Automation, and Response) Sistema	Splunk SOAR, Corteza SOAR	Más grande SOC los equipos pueden usar SOAR Agregar y centralizar alertas de múltiples soluciones
ITSM Sistema	Jira, La Colmena	Algunos equipos pueden tener una gestión de tickets personalizada (ITSM) configurado

		usando una solución dedicada.

Role in Alert Triage

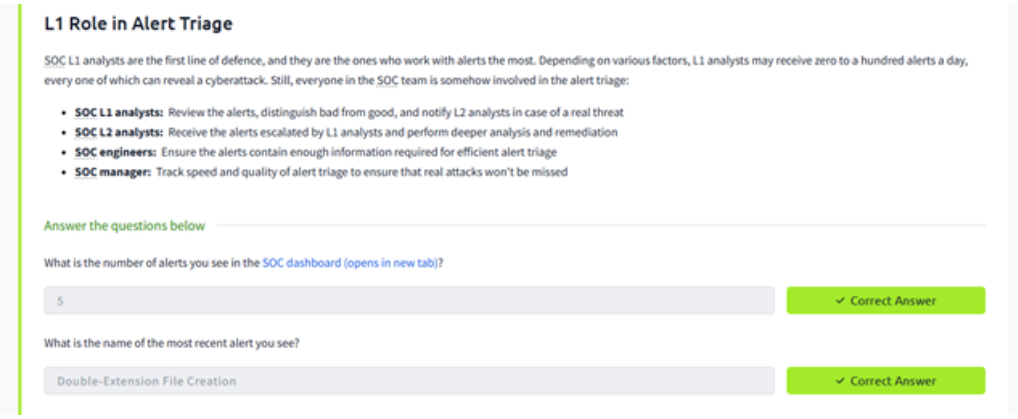
Los analistas de nivel 1 son la primera línea de defensa, y son los que más trabajan con alertas. Dependiendo de varios factores, los analistas L1 pueden recibir entre cero y cien alertas al día, todas ellas pueden revelar un ciberataque. Aun así, todos en el SOC El equipo está de alguna manera involucrado en el Alert Triage.

· SOC L1 analysts: revisa las alertas, distingue lo bueno de lo malo y notifica a los analistas de nivel 2 en caso de una amenaza real.

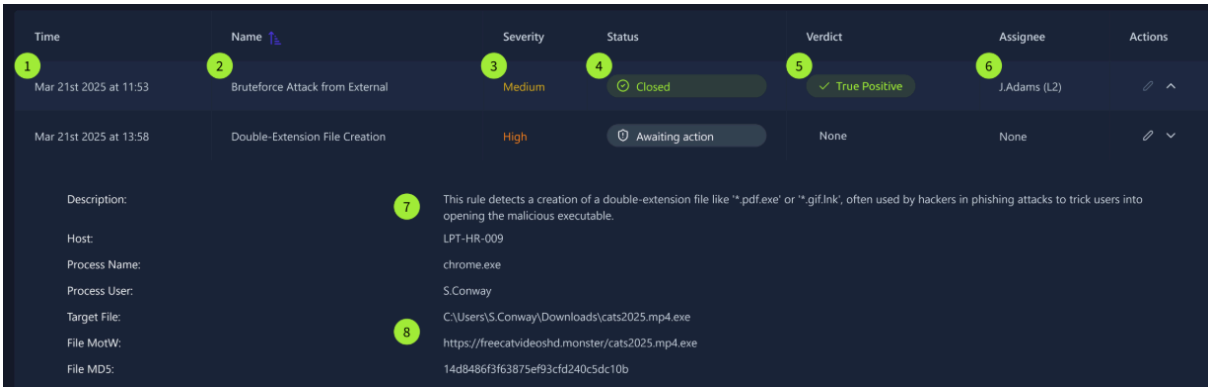
· SOC L2 analysts: recibe las alertas escaladas por los analistas L1 y realiza análisis y remediación más profundos.

· SOC engineers: se asegura de que las alertas contengan la información necesaria para un Alert Triage.

· SOC manager: realiza un seguimiento de la velocidad y calidad del Alert Triage para asegurarte de que no se pierdan ataques reales.

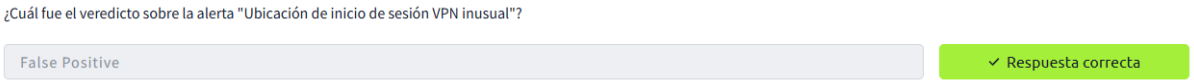


Task 3. Alert properties

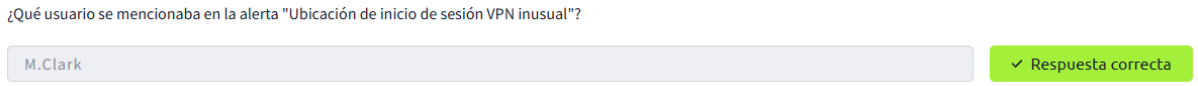


1. **Hora de alerta**
2. **Nombre de la alerta**
3. **Gravedad de la alerta**
4. **Estado de alerta**
5. **Veredicto de alerta**
6. **Asignado de alerta**
7. **Descripción de la alerta**
8. **Campos de alerta**

What was the verdict for the "Unusual VPN Login Location" alert?



What user was mentioned in the "Unusual VPN Login Location" alert?



Task 4. Alert prioritisation

➢ La **priorización de alertas** es el proceso sistemático para decidir qué alertas investigar primero cuando hay muchas en cola. Su objetivo es maximizar la probabilidad de detectar y contener amenazas reales con los recursos disponibles, minimizando el tiempo hasta la contención y reduciendo el ruido operativo. Priorizar bien requiere combinar información técnica, contexto del negocio y criterios operativos reproducibles. Anteriormente en la segunda tarea donde hay varias alertas debemos decidir cúal escoger de primero esto

es Priorización de Alertas, y es crucial para garantizar la detección oportuna de una amenaza.



Elegir la alerta adecuada

- Cada equipo de un SOC define sus propias reglas de priorización y normalmente las automatiza configurando la lógica de clasificación de alertas en el SIEM o en la plataforma EDR. A continuación, se presenta una versión mucho más adecuada con genéricamente, sencillez y método más común:
    1. Filtrar las alertas
        - Acepta sólo alertas nuevas, no vistas y sin resolver; no tomes las marcadas como revisadas, en progreso, asignadas o en investigación, ni las que ya tengan ticket o notas de otro analista. Verifica que tengan los campos mínimos (equipo, proceso, usuario, fecha/hora, severidad, id de alerta); si falta algo márcala como necesita enriquecimiento y no la aceptes.

    2. Ordenar por gravedad
        - Atiende primero las críticas, luego las altas, después las medias y por último las bajas, las alertas críticas suelen indicar mayor probabilidad de amenaza real y mayor impacto, por eso requieren respuesta y recursos inmediatos; las altas también deben tratarse rápido, mientras que las medias y bajas pueden priorizarse según carga y contexto.

    3. Ordenar por fecha
        - Priorizar las más antiguas y luego las más recientes, lo antiguo ayuda a detectar incidentes que ya pueden estar en fase de exfiltración o movimiento lateral; las alertas nuevas pueden

corresponder a actividades iniciales que aún se están investigando.

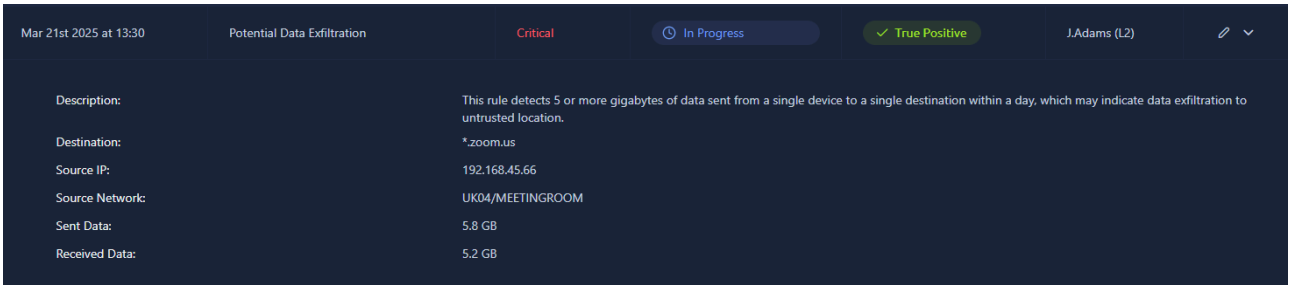
Should you first prioritise medium over low severity alerts? (Yea/Nay)



Should you first take the newest alerts and then the older ones? (Yea/Nay)



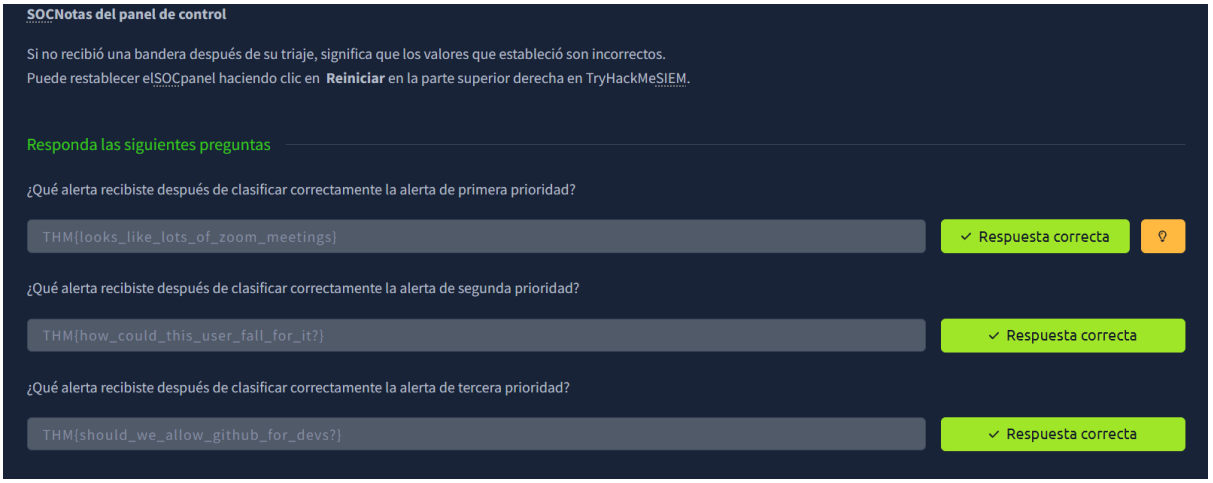
Assign yourself to the first-priority alert and change its status to **In Progress**.
The name of your selected alert will be the answer to the question.





Task 5. Alert Triage

Which flag did you receive after you correctly triaged the first-priority alert?
Which flag did you receive after you correctly triaged the second-priority alert?
Which flag did you receive after you correctly triaged the third-priority alert?



Preguntas de reflexión

¿Qué aprendieron como grupo sobre el manejo de alertas?

Como grupo aprendimos que el manejo de alertas no consiste solo en revisarlas, sino en analizarlas con contexto, priorizarlas correctamente y clasificarlas como verdaderos o falsos positivos. También entendimos la importancia del triage como proceso inicial para reducir el ruido y enfocar los esfuerzos en amenazas reales. Además, vimos cómo la correcta priorización basada en severidad e impacto es clave para una respuesta eficiente dentro del SOC.

¿Considera relevante la práctica? Explique por qué.

Sí, consideramos que la práctica es altamente relevante porque simula situaciones reales que enfrentan los analistas en un SOC. Permite aplicar conocimientos teóricos en un entorno práctico, mejorando nuestra capacidad de análisis y toma de decisiones. Además, ayuda a desarrollar habilidades críticas como la identificación de amenazas, priorización de alertas y trabajo bajo presión.

Conclusiones

El desarrollo de esta actividad permitió comprender de forma integral el funcionamiento de un SIEM y su importancia dentro de la seguridad de operaciones. Se evidenció que la centralización, normalización y correlación de logs son fundamentales para detectar amenazas de manera oportuna, ya que el análisis manual resulta insuficiente ante grandes volúmenes de datos.

Asimismo, se logró entender el rol del SOC y la importancia del trabajo en equipo entre los distintos niveles de analistas, donde cada uno cumple una función específica dentro del proceso de detección y respuesta a incidentes. El triage de alertas se identificó como una fase crítica para optimizar recursos y evitar que amenazas reales pasen desapercibidas.

Finalmente, los laboratorios permitieron aplicar los conceptos teóricos en escenarios prácticos, reforzando habilidades clave como el análisis de eventos, la priorización de alertas y la toma de decisiones. Esto demuestra que la combinación de teoría y práctica es esencial para la formación en ciberseguridad, especialmente en entornos operativos como un SOC.